

Information Security Policy

Atman · Operator: Eyob Tsegaye Yosef, Buffalo, New York, USA

Contact: eyobt646@gmail.com

Version 1.0 · Effective July 17, 2026 · Next review: July 17, 2027

1. Purpose and Scope

This policy establishes how Atman identifies, mitigates, and monitors information security risks. It covers all systems that store or process consumer data, including the iOS application, the Supabase-hosted database and authentication service, server-side Edge Functions, and third-party integrations with Plaid and OpenAI. Atman is currently operated by a single individual; this policy applies to that operator and to any future employee or contractor.

2. Roles and Responsibility

Eyob Tsegaye Yosef serves as the responsible party for information security, including risk assessment, access control, incident response, and vendor management. Security contact: eyobt646@gmail.com.

3. Risk Identification

The primary risks to consumer data are identified as: (a) unauthorized access to bank access tokens; (b) unauthorized cross-user data access; (c) credential compromise of administrative accounts; (d) exposure of secrets in source code or the distributed mobile binary; and (e) insecure data transmission. The controls below map directly to these risks.

4. Access Control

- **Row-level security.** Every database table containing consumer data enforces PostgreSQL row-level security policies scoped to the authenticated user's ID. A user cannot read or modify another user's records under any circumstance.
- **Token isolation.** Plaid access tokens are stored in a dedicated table with row-level security enabled and no client-readable policy. Tokens are readable only by the server-side service role and are never transmitted to or stored on consumer devices.
- **Least privilege.** Privileged operations — Plaid token exchange, transaction synchronization, subscription detection, balance snapshots, and account deletion — execute exclusively in server-side Edge Functions. The mobile client holds only a public anonymous key with no elevated permissions.
- **Administrative access.** Access to production infrastructure is limited to the operator and protected by multi-factor authentication on all administrative accounts, including the database and authentication platform, the Plaid Dashboard, and the source control provider.

5. Secrets Management

All third-party credentials — Plaid client ID and secret, OpenAI API key, and the database service-role key — are stored exclusively as encrypted server-side environment secrets. No secret is committed to source control, embedded in the mobile application binary, or exposed through any client-facing endpoint. Secrets are rotated upon any suspected exposure and upon operator change.

6. Encryption

- **In transit.** All communication uses HTTPS with TLS 1.2 or higher. Apple App Transport Security is enabled in the iOS application and blocks non-TLS connections. Server-side calls to the Plaid and OpenAI APIs are made exclusively over HTTPS.
- **At rest.** Consumer data is stored in a managed PostgreSQL database that encrypts data at rest using AES-256. No consumer financial data is persisted on the mobile device.
- **Device.** The operator's development machine uses full-disk encryption (FileVault) with automatic security updates enabled.

7. Consumer-Facing Security Controls

- Authentication is provided by a managed identity service using securely hashed credentials; the application never handles raw password storage.
- An application-level biometric lock (Face ID, Touch ID, or device passcode) is required to open the application, protecting data on a lost or shared device.
- Bank credentials are never seen or stored by Atman; all institution authentication occurs inside Plaid Link.

8. Secure Development

- All source code is maintained in a private repository with multi-factor authentication enforced on the account.
- Automated dependency vulnerability alerting is enabled on the repository; flagged dependencies are reviewed and updated.
- Dependencies are managed through Swift Package Manager and versioned Deno module imports, and are kept at current supported releases.
- Server infrastructure is fully managed by the hosting provider, which is responsible for operating system and database patching; the operator does not administer servers directly.

9. Vulnerability Remediation Timeframes

Vulnerabilities identified through dependency alerts, provider notifications, or responsible disclosure are triaged upon discovery and remediated according to the following targets: critical severity within 7 days, high severity within 30 days, and medium or low severity within 90 days or at the next scheduled release.

10. Monitoring

Edge Function invocation and error logs are reviewed for anomalous activity, including failed authentication attempts and unexpected error rates. Logs are configured to exclude access tokens and bank credentials. Provider security advisories for Plaid, the hosting platform, and the mobile platform are monitored and acted upon.

11. Incident Response

In the event of a suspected security incident, the operator will: (1) contain the issue, including revoking affected credentials and, where warranted, disabling affected functionality; (2) assess the scope of any consumer data exposure; (3) notify Plaid promptly in accordance with contractual obligations where Plaid-derived data may be affected; (4) notify affected consumers and any applicable regulators within the timeframes required by law; and (5) document root cause and implement corrective measures before restoring normal operation.

12. Vendor Management

Third-party processors are limited to those necessary to operate the service: Plaid (financial data connectivity), Supabase (authentication and encrypted storage), and OpenAI (assistant responses). Each is a commercially established provider with published security practices. Only the minimum data necessary is shared with each; in particular, only aggregated, summarized financial context is sent to OpenAI, never credentials or access tokens. Processors are reviewed at least annually.

13. Data Retention and Disposal

Retention periods and disposal procedures are governed by the separate Atman Data Retention and Disposal Policy, which forms part of this security program.

14. Policy Review

This policy is reviewed at least annually and upon any material change to architecture, third-party processors, or applicable regulation. Version history is maintained with each revision.

15. Contact

Eyob Tsegaye Yosef — eyobt646@gmail.com